

Teoría 3 Parte 1 - Normativas y Protocolos

Recolección y preservación de evidencia digital

Fuentes principales: ISO/IEC 27037:2012; RFC 3227; Protocolo Unificado de los Ministerios Públicos (Argentina, 2017); Protocolos nacionales 2021/2023.

1. Panorama general

La recolección forense digital exige procedimientos controlados para garantizar que la evidencia sea **relevante, confiable y suficiente** (principios de ISO/IEC 27037). Los protocolos internacionales y nacionales describen cómo **identificar, aislar, adquirir, preservar, verificar y documentar** evidencia digital, respetando privacidad y cadena de custodia.

2. Principios fundamentales (síntesis)

- **Metodología no intrusiva:** usar técnicas mínimamente intrusivas y justificables.
 - **Trazabilidad / auditoría:** todo procedimiento y herramienta debe quedar documentado y ser verificable por terceros.
 - **Reproducibilidad:** repetir el proceso bajo las mismas condiciones debe producir los mismos resultados.
 - **Defendibilidad:** poder justificar las decisiones técnicas y las herramientas usadas (por ejemplo: por qué  o por qué cierta versión de herramienta).
 - **Privacidad y legalidad:** pedir autorización escrita, limitar recolección a datos pertinentes, proteger confidencialidad.
-

3. Criterios de validez de la evidencia (ISO/IEC 27037)

- **Relevancia:** ¿la evidencia apoya la hipótesis del caso?

- **Confiabilidad:** ¿el procedimiento y las herramientas son auditables, replicables y con tasas de error conocidas?
- **Suficiencia:** ¿la evidencia es completa para sustentar conclusiones?

Pequeño chequeo: siempre conserva hashes de fuente e imagen; documenta metadatos y operadores.

4. Orden de volatilidad (prioridad de adquisición) — (RFC 3227)

Es un documento que recoge las directrices para la recopilación de evidencias y su almacenamiento, y puede llegar a servir como estándar de facto para la recopilación de información en incidentes de seguridad.

Es un documento que recoge las principales directrices para la recolección y el almacenamiento de evidencias digitales, constituyendo un verdadero estándar para la recopilación y almacenamiento de evidencias.

Define un proceso para la recolección de evidencias que ayuda al perito informático a adquirir y catalogar las evidencias digitales.

De **mayor** a **menor** volatilidad (recopilar en ese orden):

1. Registros y contenido de caches (memoria volátil de apps).
2. Tablas de enrutamiento, ARP, procesos en ejecución, estadísticas del kernel, memoria (RAM).
3. Información temporal del sistema (conexiones de red, sockets).
4. Disco (imágenes bit a bit).
5. Logs del sistema (archivos persistentes).
6. Configuración física / topología de red.
7. Documentos (archivos, papel).

Regla práctica: si el equipo está encendido, recopilar RAM / procesos / conexiones antes de apagar.

5. Fases operativas resumidas

Fase 1 — Preparación y Aislamiento

- **Objetivo:** evitar modificación de evidencia.

- **Encendido:** si está encendido, realizar **volcado de memoria** (no "extraer físicamente" la RAM) y luego apagado controlado si procede.
- **Apagado:** lo ideal: NO encender el sistema. Extraer disco y montar en estación forense con **write-blocker**.
- **Documentación inicial:** modelo, número serie, hora, estado físico, propietario. Fotografiar.

Fase 2 — Adquisición (imagen forense)

- Conectar mediante **write-blocker**.
- Elegir formato de imagen (RAW / E01), destino y metadatos del caso.
- Realizar **imagen bit a bit** (herramientas: **dd**, **dc3dd**, Guymager, FTK Imager).
- Calcular hashes (MD5, SHA-1, SHA-256) durante y al finalizar.

Fase 3 — Verificación y documentación

- Comparar hashes de fuente e imagen.
- Generar informe de adquisición: fechas, hashes, tamaño, errores, operadores.
- Actualizar **cadena de custodia** (quién, cuándo, dónde).

6. Actuación en la escena / allanamiento (resumen práctico)

- **Separar** a usuarios y testigos; documentar quiénes estaban presentes.
- **Fotografiar** equipos antes de mover.
- **No presionar teclas** ni intentar acceder a datos sin perito.
- **Equipos apagados:** mantener apagados; desconectar de la red y extraer si corresponde.
- **Equipos encendidos:** consultar especialista; si no hay perito, desconectar alimentación del gabinete (más seguro que apagar por software para evitar sobrescrituras de logs), o aislar en bolsa Faraday si debe permanecer encendido.
- **Teléfonos móviles:** preferir extraer batería; si no posible, activar modo avión y usar bolsa Faraday. Documentar contradicciones y justificar cada

acción.

- **Etiquetado:** rotular cada elemento con expediente, fecha, hora, número de serie, persona que lo incauta, precinto, etc.
 - **Embalaje:** usar bolsas antiestáticas, contenedores resistentes; indicar peligrosidad (biológicos o químicos).
-

7. Cadena de custodia — elementos mínimos

- Identificador del caso.
 - Identificador del objeto.
 - Fecha y hora de cada transferencia.
 - Nombre y firma del responsable de cada movimiento.
 - Motivo de transferencia.
 - Estado físico y observaciones.
-

8. Herramientas y utilidades típicas (práctico)

- **Volcado / imágenes:** `dd`, `dc3dd`, Guymager, FTK Imager, EnCase.
 - **Hashes / integridad:** `md5sum`, `sha1sum`, `sha256sum`, funciones de E01 (EnCase).
 - **Estado vivo / diagnóstico:** `ps`, `netstat` / `ss`, `ifconfig` / `ip`, `arp`, `lsof`.
 - **Memoria:** `gcore`, `volatility`, `LIME` (Linux memory extraction), `WinPMEM` (Windows).
 - **Carving / recuperación:** `foremost`, `scalpel`, `photorec`, Autopsy/Sleuth Kit.
 - **Transporte remoto (ej.):** `nc` + `dd` (útil, pero sin cifrado ni autenticación por defecto — usar canales seguros o herramientas forenses).
 - **Bloqueo de escritura:** hardware write-blocker (preferible) o mecanismos software con precaución.
-

9. Consideraciones legales y de privacidad

- Siempre obtener **autorización judicial o por escrito** según jurisdicción.
- Minimizar recolección de datos personales no relevantes.

- Proteger disponibilidad de servicios críticos (coordinar con TI).
 - Documentar motivos para cualquier acción que pueda afectar privacidad o disponibilidad.
-

10. Protocolos nacionales (Argentina)

- **Protocolo unificado (2017):** énfasis en representatividad, identidad, integridad y cadena de custodia. Evitar secuestros masivos; priorizar elementos con alta probabilidad de contener evidencia.
 - **Protocolos 2021/2023:** introducen la figura del **Especialista en informática forense** con responsabilidades definidas; listan PEPS (Potenciales Elementos de Prueba) y pautas de actuación.
 - **Operativa específica:** usar guantes, bolsas antiestáticas/Faraday, fotografiar, rotular, registrar contraseñas y usuarios si posible.
-

3.1 Protocolo unificado de los Ministerios Públicos (2017)

- Guía para **levantamiento y conservación de evidencia**.
- Define principios y condiciones generales de aceptación en laboratorios forenses.
- Requiere documentar **cadena de custodia** desde el levantamiento hasta el análisis.

Principios generales

- **Representatividad:** evidencias vinculadas correctamente al lugar, tiempo y hechos.
- **Identidad:** identificación clara e indeleble (materiales resistentes, etiquetas a prueba de agua).
- **Integridad:** envases resistentes, herméticos, sin pérdidas.
- **Peligrosidad:** declaración escrita en caso de sustancias peligrosas.

Elementos para la identificación

- Lugar, hora, fecha, tipo de muestra.
- Número de causa, juez/fiscal interviniente.

- Firmas de responsables.
- Precinto.
- Planilla de cadena de custodia firmada por cada interviniente.

3.2 Evidencias digitales – Principios generales

- **Qué son:** PC, notebooks, tablets, celulares, pendrives, CD/DVD, discos duros, servidores.
- **Operativa:**
 - Secuestro selectivo, no masivo.
 - Evitar manipulación de equipos (no encender, no presionar teclas).
 - Documentar y fotografiar todo.
 - Respetar **orden de volatilidad** (primero registros en memoria, luego disco).
 - Usar guantes y bolsas antiestáticas/Faraday.

TIPO DE MUESTRA	RECOLECCIÓN	PREPARACIÓN	EMBALAJE
Estado de la memoria RAM	Capacidad de los programas cargados. Bloqueos. Porcentaje de uso		
Procesos activos	Uso de CPU. Dependencias de procesos y componentes		
Conexiones de red	Conexiones actuales con otras PC y servidores	Identificación de elementos con respaldo de impresiones, fotografías y actas	No instalar programas en las PC. Realizar las operaciones con los equipos encendidos y cables conectados
Impresiones activas	Cola de impresión local. Documentos sin imprimir. Estado y descripción de los documentos que se están imprimiendo		
Fecha y hora del sistema operativo	Fecha y hora del sistema operativo. Zona horaria. Sincronizaciones con servidores de hora en Internet		
Red de la empresa u organización	Características. Tráfico. Congestión. Bloqueos. Snifers activos. Virus de red		

TIPO DE MUESTRA	RECOLECCIÓN	PREPARACIÓN	EMBALAJE
Papeles impresos	Recolección de papeles impresos en el lugar	Identificación de elementos con respaldo de fotografías y actas	
Conexiones físicas de red	Cableados existentes. Hubs. Switchs	Identificación de elementos con respaldo de fotografías y actas	No desconectar hasta tanto se recolecte y documente la evidencia

3.3 Pasos en la escena del crimen / allanamiento

- Separar usuarios de los dispositivos.
- Identificar personal informático interno (admins, programadores).
- Obtener contraseñas y patrones de bloqueo.
- Fotografiar equipos antes de moverlos.
- Equipos apagados → mantener apagados.
- Equipos encendidos → consultar especialista, de no haberlo, desconectar cable de corriente del gabinete.
- Celulares → apagar, extraer batería si es posible, activar modo avión, proteger botón de encendido.
- Dispositivos en uso → si es necesario mantenerlos encendidos, aislar en bolsa de Faraday.
- Registrar todo cambio realizado.

3.4 Protocolo de Actuación para la Investigación Científica en el Lugar del Hecho (2021)

- Introduce la figura del **Especialista en informática forense**.
- Define sus **responsabilidades, atribuciones y funciones**.
- Enumera los **PEPS (Potenciales Elementos de Prueba)** a identificar.
- Establece pautas para:
 - Actuación en distintas situaciones.
 - Solicitud de autorizaciones.

- Forma de informar hallazgos.
- Reafirma la importancia de la **cadena de custodia**.

11. Buenas prácticas resumidas (lista rápida para memorizar)

- No tocar (ni apagar) si no sabes qué hacer: documenta y consulta perito.
 - Si encendido: volcado de RAM primero.
 - Usar write-blocker antes de imagenar discos.
 - Calcular y conservar hashes (antes/durante/después).
 - Documentar todo (quién, cuándo, cómo, por qué).
 - Priorizar volatilidad: RAM → procesos → disco → logs → configuración → documentos.
 - No ejecutar herramientas no forenses en la evidencia (risk of contamination).
 - Proteger la cadena de custodia.
 - Respetar privacidad y requerir autorizaciones.
-